

Cisco Switch STIG

Topic:

STIGing a Cisco Switch

Purpose:

To teach you how to STIG a switch, (hopefully without breaking everything)

Scope:

Primary focus will be actually configuring the switch, not Windows server/ ISE

Prereq:

1. Down time scheduled with your IT business partner or Project Manager
2. Cisco Switch
3. Console cable
4. Local login to your switch, and to a PC near your switch
5. Putty or putty alternative

Optional:

STIG Viewer and latest Cisco Switch STIGs

<https://public.cyber.mil/stigs/srq-stig-tools/>

Copy and Paste Notes:

<https://github.com/fnitguy-tech/fnitguy-tech>

Lab Switch Credentials:

```
username fnitguy privilege 15 common-criteria-policy PASSWORD_POLICY secret cH2UY3RzR542U4@|
enable secret cH2UY3RzR542U4@|
```

NDM w/ explain

This covers 28 rules of 48.

This is just enabling logging

```
configure terminal
archive
log config
logging enable
logging buffered 99999999 informational
logging userinfo
logging trap informational
login on-failure log
login on-success log
service timestamps log datetime localtime
```

This is making it so you're locked out for 15 minutes IF you enter your password incorrectly 3 times with 120 seconds

login block-for 900 attempts 3 within 120

This makes sure that no passwords are stored in plain text.
service password-encryption

You shouldn't be using a web gui.

ip http secure-server
ip http max-connections 2
ip http authentication aaa login-authentication LOGIN_AUTHENTICATION
ip http timeout-policy idle 300 life 1000 requests 99

We like SSH to be secure

ip ssh version 2
ip ssh server algorithm encryption aes256-ctr aes192-ctr aes128-ctr
ip ssh server algorithm mac hmac-sha2-512 hmac-sha2-256

Disables a whole bunch of stuff you probably don't use. Might break PXE boot.

no boot network
no ip boot server
no ip bootp server
no ip domain lookup
no ip dns server
no ip identd
no ip finger
no ip http server
no ip rcmd rcp-enable
no ip rcmd rsh-enable
no service config
no service finger
no service tcp-small-servers
no service udp-small-servers
no service pad
no service call-home
no call-home

Self explanatory or explained elsewhere

aaa new-model
aaa authentication login CONSOLE local
aaa common-criteria policy PASSWORD_POLICY
min-length 16
upper-case 1
lower-case 1
numeric-count 1
special-case 1
char-changes 8
end

Banners, you really only need a login banner; but I have MOTD here too just for fun.
conf t

banner login #

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services

by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and

confidential. See User Agreement for details. #

end

conf t

banner motd #

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services

by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and

confidential. See User Agreement for details. #

end

```
### Not sure why the STIGs want this, extended access lists don't do anything unless applied somewhere
conf t
ip access-list extended BLOCK_INBOUND
deny icmp any any log-input
end
```

```
### This is to restrict SSH traffic to whatever subnet you decide.
conf t
ip access-list extended MANAGEMENT_NET
deny ip any any log-input
end
```

```
### Limits how many people can SSH in at a time.
conf t
line con 0
login authentication CONSOLE
exec-timeout 5 0
```

```
line vty 0 1
transport input ssh
exec-timeout 5 0
```

```
line vty 2 15
transport input none
```

```
end
write memory
```

###this uses tftp to back up your config everytime you make a change. You'll add your tftp server here.

```
event manager applet BACKUP_CONFIG
event syslog pattern "%SYS-5-CONFIG_I"
action 1 cli command "enable"
action 2 info type routename
action 3 cli command "copy run tftp" pattern "remote host"
action 4 cli command "192.168.1.43" pattern "filename"
action 5 cli command "$_info_routename-config"
action 6 syslog priority informational msg "Configuration backup was executed"
```

Copy and Paste

```
configure terminal
archive
log config
logging enable
```

logging buffered 99999999 informational
logging userinfo
logging trap informational
login on-failure log
login on-success log
login block-for 900 attempts 3 within 120
service timestamps log datetime localtime
service password-encryption

ip http secure-server
ip http max-connections 2
ip http authentication aaa login-authentication LOGIN_AUTHENTICATION
ip http timeout-policy idle 300 life 1000 requests 99
ip ssh version 2
ip ssh server algorithm encryption aes256-ctr aes192-ctr aes128-ctr
ip ssh server algorithm mac hmac-sha2-512 hmac-sha2-256

no boot network
no ip boot server
no ip bootp server
no ip domain lookup
no ip dns server
no ip identd
no ip finger
no ip http server
no ip rcmd rcp-enable
no ip rcmd rsh-enable
no service config
no service finger
no service tcp-small-servers
no service udp-small-servers
no service pad
no service call-home
no call-home

aaa new-model
aaa authentication login CONSOLE local
aaa common-criteria policy PASSWORD_POLICY
min-length 15
upper-case 1
lower-case 1
numeric-count 1
special-case 1
char-changes 8
end

conf t
banner login #

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to,

penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services

by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and

confidential. See User Agreement for details. #

end

conf t

banner motd #

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement

(LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services

by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and

confidential. See User Agreement for details. #

end

conf t

ip access-list extended BLOCK_INBOUND

```
deny icmp any any log-input
end

conf t
ip access-list extended MANAGEMENT_NET
deny ip any any log-input
end

conf t
line con 0
login authentication CONSOLE
exec-timeout 5 0

line vty 0 1
transport input ssh
exec-timeout 5 0

line vty 2 15
transport input none

end

write memory
```

User input required

This is where you'll put splunk, or whatever server you forward your logs to. Default port is UDP 514, but it's superior to put it on TCP. AS LONG as your log server is listening on that port.

```
logging host x.x.x.x
logging host 192.168.1.43 transport tcp port 514
```

Gather all the subnets you want to be able to access your switches on, ideally you'll have one workstation. But it's up to you.

```
ip access-list extended MANAGEMENT_NET
permit ip 192.168.1.0 0.0.0.255 any
deny ip any any log-input
```

This is you applying the extended access-list to your vty lines, that way they actually take affect.

```
line vty 0 1
access-class MANAGEMENT_NET in
```

This will probably already be done, but if your enable secret shows 5 instead of 9, do it again.

```
username XXXXXXXX privilege 15 common-criteria-policy PASSWORD_POLICY secret XXXXXXXXXXXXXXXX
```

enable secret xxxxxxxxxxxx

ex:

```
username fnitguy privilege 15 common-criteria-policy PASSWORD_POLICY secret ch2UY3RzR542U4@|
enable secret ch2UY3RzR542U4@|
```

You're required to have two NTPs, good luck!

```
ntp authenticate
```

```
ntp authentication-key 1 md5 xxxxxx
```

```
ntp trusted-key 1
```

```
ntp server x.x.x.x key 1
```

```
ntp server y.y.y.y key 1
```

sh clock, to make sure it's syncing up.

I haven't tested these commands because I don't use SNMP in my enviroment, so good luck.

```
snmp-server group V3GROUP v3 auth read V3READ write V3WRITE
```

```
snmp-server user V3USER V3GROUP v3 auth sha xxxxxx priv aes 256 xxxxxx
```

```
snmp-server view V3READ iso included
```

```
snmp-server view V3WRITE iso included
```

```
snmp-server host x.x.x.x version 3 auth V3USER
```

####RADIUS, this can be tricky but here's what it should look like

It's really easy to export your NPS config file and import it to another server. I highly recommend you do this. Your key needs to match whatever you put in as your secret on your NPS.

```
conf t
```

```
radius server RADIUS_1
```

```
address ipv4 192.168.1.110
```

```
key YourP@$W0rdH3re!
```

```
radius server RADIUS_2
```

```
address ipv4 192.168.1.111
```

```
key YourP@$W0rdH3re!
```

```
aaa group server radius RADIUS_SERVERS
```

```
server name RADIUS_1
```

```
server name RADIUS_2
```

You want your source-interface to match the I.P you have in your NPS as your radius client. If you have multiple layer 3 interfaces on your switch, it will likely try to authenticate with the WRONG I.P

```
ip radius source-interface vlan 22
```

When you apply this to line con 0, it's saying if you're using a console cable, login locally.

```
aaa authentication login CONSOLE local
```

This is creating a login group you will apply to your vty lines.

aaa authentication login LOGIN_AUTHENTICATION group radius group RADIUS_SERVERS local

Make sure this is set up on both sides before you apply it to your VTY lines, OR ELSE you'll be locked out. I highly recommend you keep an SSH session open while trying to get radius working.

line vty 0 1

login authentication LOGIN_AUTHENTICATION

exit

line con 0

login authentication CONSOLE

###this uses tftp to back up your config everytime you make a change. You'll add your tftp server here.

event manager applet BACKUP_CONFIG

event syslog pattern "%SYS-5-CONFIG_I"

action 1 cli command "enable"

action 2 info type routename

action 3 cli command "copy run tftp" pattern "remote host"

action 4 cli command "192.168.1.43" pattern "filename"

action 5 cli command "\$_info_routename-config"

action 6 syslog priority informational msg "Configuration backup was executed"

****MODIFY* Copy and Paste***

logging x.x.x.x

logging y.y.y.y

ip access-list extended MANAGEMENT_NET

permit ip x.x.x.0 0.0.0.255 any

deny ip any any log-input

username XXXXXXXX privilege 15 common-criteria-policy PASSWORD_POLICY secret XXXXXXXXXXXXXXXX

enable secret xxxxxxxxxxxx

ntp authenticate

ntp authentication-key 1 md5 xxxxxx

ntp trusted-key 1

ntp server x.x.x.x key 1

ntp server y.y.y.y key 1

snmp-server group V3GROUP v3 auth read V3READ write V3WRITE

snmp-server user V3USER V3GROUP v3 auth sha xxxxxx priv aes 256 xxxxxx

snmp-server view V3READ iso included

```
snmp-server view V3WRITE iso included
snmp-server host x.x.x.x version 3 auth V3USER
```

```
conf t
radius server RADIUS_1
address ipv4 192.168.1.200
key P@$W0rd123!
```

```
radius server RADIUS_2
address ipv4 192.168.1.201
key YourP@$W0rdH3re!
```

```
aaa group server radius RADIUS_SERVERS
server name RADIUS_1
server name RADIUS_2
```

```
ip radius source-interface vlan 22
aaa authentication login CONSOLE local
aaa authentication login LOGIN_AUTHENTICATION group radius group RADIUS_SERVERS local
aaa authorization exec default radius local
```

```
line vty 0 1
login authentication LOGIN_AUTHENTICATION
access-class MANAGEMENT_NET in
exit
line con 0
login authentication CONSOLE
```

L2S w/ explain

This is setting up the capability for dot1x, doesn't do anything until other commands are applied to the interfaces.

```
aaa authentication dot1x default group RADIUS_SERVERS
dot1x system-auth-control
```

VLAN Trunking protocol. This is making it so if you want your downstream switches to get the VLANs on the core, they need this matchy matchy

```
vtp domain fnitguy.tech
vtp password Ch@ng3m3pl34se!
```

QOS command that i've never seen a switch take.
mls qos; this should be happening by default after IOS 15

###Keep spanning tree loop free, flappy switches aren't good for users.

spanning-tree loopguard default

###THIS WILL BREAK EVERYTHING IF DONE IMPROPERLY. You need to identify the path port by port to your DHCP server and add the command "ip dhcp snooping trust" all the way to your DHCP Server. Turn on DHCP snooping on user VLANs and let it run for a day longer than your DHCP lease times WITHOUT ARP inspection. Test this before you roll it out.

ip dhcp snooping vlan 2,4-8,11

ip dhcp snooping

###ARP inspection will break everything if DHCP snooping hasn't built its database yet.

ip arp inspection vlan 2,4-8,11

ip igmp snooping

###If your environment already uses spanning tree, be careful.

spanning-tree mode mst

or

spanning-tree mode pvst

udld enable

Shutdown VLAN 1, create a shutdown vlan for unused ports, and create a native vlan; if your environment is all on vlan 1. This will take some planning, proceed w caution.

conf t

int vlan 1

no ip address

shutdown

description SHUTDOWN

vlan 1

name SHUTDOWN

vlan 999

name Blackhole_VLAN

shutdown

vlan 2000

name Native_VLAN

Shutdown all unused ports; be careful here too.

sh int status | i notconnec

int range g1/0/1,g1/0/6-9

shutdown

switchport access vlan 999

###host facing INTERFACE commands:

Dont do this until you've done extensive testing. Anything that doesn't have a certificate on your network will be broken. Leave this off of server facing ports, and off of printers until you set up a MAB, off of anything that doesn't have a certificate for that matter.

```
int range g1/0/1-8
authentication host-mode single-host
dot1x pae authenticator
authentication port-control auto
```

```
### Compensating control if you don't have dot1x set up yet.
switchport port-security
switchport port-security mac-add sticky
```

```
### IP Verify source depends upon the database that dhcp snooping builds and static ip source binding.
Implement with caution.
ip verify source
```

```
### This command basically stops ARP traffic flooding out interfaces if the mac address isn't known. Be careful
implementing this
switchport block unicast
```

```
### bpduguard enable will err-disable any ports that receive bpdus or spanning tree traffic. Its fine to assign this
to access ports, but if you assign it to a trunk port that has a switch connected. UHOH you're users all just lost
connectivity.
spanning-tree bpduguard enable
```

```
### This throttles speeds if the traffic exceeds the limit you set. You want to be very careful, as this will make
your network unusable if you assign it to anything other than host facing ports, OR if you enter in the number too
low.
storm-control unicast level bps 1000000000
storm-control broadcast level bps 1000000000
```

```
### Trunk port commands;
switchport trunk encapsulation dot1q
switchport mode trunk
switchport nonegotiate
switchport trunk allowed vlan 2-998,1000-4094
switchport trunk native vlan 2000
```

L2S - Just Commands

```
aaa authentication dot1x default group RADIUS_SERVERS
dot1x system-auth-control
```

```
vtp domain fnitguy.tech
vtp password Ch@ng3m3pl34se!
```

```
spanning-tree loopguard default
```

```
ip igmp snooping
ip dhcp snooping
ip dhcp snooping vlan 2,4-8,11
ip arp inspection vlan 2,4-8,11
spanning-tree mode mst
udld enable
```

```
conf t
int vlan 1
no ip address
shutdown
description SHUTDOWN
```

```
vlan 1
name SHUTDOWN
```

```
vlan 999
name Blackhole_VLAN
shutdown
```

```
int range g1/0/2-12
switchport port-security
switchport port-security mac-add sticky
ip verify source
switchport block unicast
spanning-tree bpduguard enable
storm-control unicast level bps 1000000000
storm-control broadcast level bps 1000000000
```